

1. Introducción

Mi documento desarrolla de forma detallada los procesos fundamentales de un SOC enfocados en la detección, análisis y respuesta a incidentes de seguridad informática se abordan metodologías prácticas utilizadas en entornos reales, integrando conceptos como correlación de eventos, clasificación de alertas, gestión de falsos positivos y análisis de amenazas avanzadas como ransomware.

El objetivo es demostrar cómo un analista SOC Nivel 1 interpreta eventos, toma decisiones basadas en evidencia y contribuye a la protección de los activos organizacionales, especialmente en entornos críticos donde la disponibilidad y la integridad de la información son esenciales.

2. Arquitectura del SOC

El SOC se apoya en una arquitectura centralizada que permite la visibilidad completa de la infraestructura, facilitando la detección temprana de amenazas y la respuesta oportuna.

Fuentes de datos:

- Sistemas operativos event logs, syslogs
- Dispositivos de red firewalls, IDS/IPS
- Herramientas EDR actividad del endpoint
- Aplicaciones empresariales logs de autenticación, bases de datos
- Inteligencia de amenazas feeds externos

Flujo detallado:

2.1 Recolección

Se recopilan logs en tiempo real desde múltiples fuentes mediante agentes o syslog.

2.2 Normalización

Los datos se transforman a un formato estándar para facilitar su análisis.

2.3 Enriquecimiento

Se añade contexto como:

- Geolocalización de IP
- Reputación de dominios

Información del usuario

2.4 Correlación

Se relacionan múltiples eventos para identificar patrones sospechosos dentro del SIEM.

2.5 Generación de alertas

El SIEM genera alertas basadas en reglas o comportamiento anómalo.

2.6 Análisis

El analista evalúa la alerta utilizando evidencia disponible.

2.7 Respuesta

Se ejecutan acciones como bloqueo, aislamiento o escalamiento.

3. Proceso SOC L1

3.1 Recepción de alerta

El analista recibe alertas generadas por el SIEM, las cuales pueden ser:

Basadas en firmas

Basadas en comportamiento

Basadas en correlación

3.2 Validación

Se verifica la legitimidad de la alerta revisando:

Origen del evento

Integridad de los logs

Usuario involucrado

Activo afectado

3.3 Análisis técnico

Incluye:

Revisión de logs detallados

Análisis de tráfico de red

Identificación de patrones anómalos
Comparación con comportamientos normales

3.4 Clasificación

Se asigna una severidad considerando múltiples factores.

3.5 Escalamiento

Se escalan incidentes que requieren mayor profundidad de análisis.

3.6 Documentación

Se documenta:

Descripción del evento
Evidencia
Acciones realizadas
Resultado final

Ejemplo integrado

Un analista recibe una alerta por múltiples intentos fallidos de inicio de sesión. Tras validar los logs, identifica un acceso exitoso desde una ubicación inusual. Se clasifica como alta y se escala a SOC L2.

4. Clasificación de Alertas

Niveles de severidad:

Nivel	Descripción
Crítica	Incidente activo con impacto directo
Alta	Alta probabilidad de compromiso
Media	Evento sospechoso
Baja	Actividad inusual
Informativa	Sin impacto

Factores de evaluación:

Impacto en el negocio
Probabilidad de explotación
Criticidad del activo

Nivel de exposición

5. Correlación de Eventos

La correlación permite identificar ataques complejos que no pueden detectarse mediante eventos individuales, siendo una funcionalidad clave en plataformas SIEM.

Tipos de correlación:

Temporal
Secuencial
Basada en comportamiento

Ejemplo avanzado:

15 intentos fallidos de login
Login exitoso desde país diferente
Acceso a múltiples servidores

Interpretación: posible ataque de fuerza bruta seguido de acceso comprometido.

6. Gestión de Falsos Positivos

Importancia:

Reducir falsos positivos evita la fatiga del analista y mejora la eficiencia operativa del SOC.

Causas detalladas:

Configuración incorrecta de reglas
Cambios en la infraestructura
Falta de contexto organizacional

Proceso completo:

1. Análisis de logs
2. Correlación de eventos
3. Validación con contexto
4. Confirmación con usuario o sistema

Ejemplo:

Un alto volumen de tráfico puede representar:

Ataque DDoS
Actividad legítima de respaldo

7. Caso de Uso: Ransomware

Descripción del ataque:

El ransomware cifra archivos y afecta directamente la continuidad operativa de la organización.

Fases detalladas:

1. Acceso inicial
2. Persistencia
3. Movimiento lateral
4. Escalada de privilegios
5. Desactivación de defensas
6. Eliminación de copias de seguridad
7. Cifrado de archivos

Indicadores clave:

Eliminación de shadow copies
Procesos desconocidos
Alta actividad de escritura

Impacto:

Interrupción de servicios
Pérdida de información
Riesgo financiero y reputacional

8. Indicadores de Compromiso (IoC)

Los IoC permiten identificar actividad maliciosa.

Ejemplos:

- IPs sospechosas
- Hashes de malware
- Dominios maliciosos
- Procesos anómalos

9. Métricas del SOC

MTTD

Tiempo promedio en detectar un incidente.

MTTR

Tiempo promedio en responder a un incidente.

Tasa de falsos positivos

Porcentaje de alertas incorrectas.

Tiempo de análisis

Tiempo promedio de evaluación por alerta.

Estas métricas permiten evaluar y mejorar continuamente la eficiencia del SOC.

10. Mejora Continua

El SOC debe adaptarse constantemente:

- Ajuste de reglas SIEM
- Incorporación de nuevas amenazas
- Evaluación de desempeño
- Capacitación del personal

11. Conclusión

La operación de un SOC requiere integración de tecnología, procesos y análisis humano. La correcta gestión de alertas, junto con la correlación de eventos y la reducción de falsos positivos, permite detectar amenazas de forma eficiente.

Un SOC bien implementado contribuye directamente a la seguridad, continuidad y resiliencia de la organización.

12. Referencias

Bejtlich, R. (2013). *The practice of network security monitoring*. No Starch Press.

ENISA. (2022). *Threat landscape report*. <https://www.enisa.europa.eu>

International Organization for Standardization. (2016). *ISO/IEC 27035: Information security incident management*.

MITRE Corporation. (2023). *MITRE ATT&CK framework*. <https://attack.mitre.org/>

National Institute of Standards and Technology. (2012). *Computer security incident handling guide (SP 800-61)*.

Scarfone, K., & Mell, P. (2007). *Guide to intrusion detection and prevention systems (IDPS)*. NIST.

Verizon. (2023). *Data breach investigations report*.